

# PrimeHealth Clinic & Diagnostics

## Standards, Frameworks & Regulations

Version 1.0

| No | Name                                        | Description                                                                                                                                                                                                                                                                                                                                                             | Type             | Mandatory / Optional | Justification                                                                                                                                                                                                                                   |
|----|---------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1  | NPAAC Standards                             | <p>The National Pathology Accreditation Advisory Council (NPAAC) develops and maintains the accreditation standards for pathology laboratories in Australia.</p> <p>These standards are developed to ensure consistency in pathology practice in Australia and protect the public from harm.</p>                                                                        | Standard         | Mandatory            | The requirements are mandatory. They <b>must</b> be met if a company wants to provide pathology services.                                                                                                                                       |
| 2  | Health Practitioner Regulation National Law | The Health Practitioner Regulation National Law (HPRNL) establishes the Australian Health Practitioner Regulation Agency (AHPRA) to manage applications for registration of health practitioners, receive an investigate reports and/or complaints of the conduct and performance of health practitioners, and to maintain a register (public) of health practitioners. | Regulation       | Mandatory            | While the HPRNL itself doesn't specifically mention pathology, it applies to all practitioners in the health field. Pathologists are considered health practitioners and must comply with this law, which ensures qualification and competence. |
| 3  | Therapeutic Goods Act (1989)                | <p>This Act is administered by the Therapeutic Goods Administration (TGA).</p> <p>The TGA regulates therapeutic goods by:</p> <ul style="list-style-type: none"> <li>- Approving commercial supply of therapeutic goods for use in Australia.</li> </ul>                                                                                                                | Regulation (Law) | Mandatory            | Pathology labs must comply with the TGA regulations because the TGA ensures that the goods used for pathology diagnostic tests meet the safety, quality, and performance standards.                                                             |

|   |                                                           |                                                                                                                                                                                                                                                                                                                                                                                            |            |           |                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|---|-----------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   |                                                           | <ul style="list-style-type: none"> <li>- Maintains an electronic register of therapeutic goods (called the ARTG).</li> <li>- Monitors the safety of these therapeutic goods through various means (official reports, community complaints, etc.)</li> <li>- Approves products for manufacturing if they meet the required standards.</li> </ul>                                            |            |           |                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| 4 | ISO/IEC 17025                                             | It is an international standard for testing and calibration laboratories. It sets out requirements for the competence, impartiality, and consistent operation of laboratories, ensuring the accuracy and reliability of their testing and calibration results.                                                                                                                             | Standard   | Mandatory | This standard is mandatory for Primehealth's laboratories as it enhances the credibility of testing and calibration work, fostering trust among clients and regulatory authorities                                                                                                                                                                                                                                                               |
| 5 | Spam Act 2003                                             | It is an Australian law that regulates commercial electronic messages. It prohibits the sending of unrequested commercial electronic messages—known as spam—with an Australian link.                                                                                                                                                                                                       | Regulation | Mandatory | The Spam Act 2003 is mandatory for Primehealth to ensure email communications to clients are conducted legally, including obtaining proper consent, providing clear opt-out options, and avoiding unsolicited messages.                                                                                                                                                                                                                          |
| 6 | Australian Cyber Security Centre (ACSC) Essential Eight   | The Australian Cyber Security Centre (ACSC) established the Essential 8 cyber security framework, which is a prioritised list of eight mitigation methods aimed to strengthen an organization's resistance to different cyber-attacks. This framework is essential for protecting sensitive data and maintaining strong security systems.                                                  | Regulation | Mandatory | Implementing the ACSC Essential Eight at Prime Health Clinic and Diagnostics will improve cybersecurity by safeguarding sensitive data, maintaining regulatory compliance, and mitigating risks. These approaches will increase patient trust, enhance incident response, and promote a security-conscious culture among personnel. Finally, this approach will help us maintain operational efficiency and protect our vital healthcare assets. |
| 7 | Digital Transformation Agency (DTA) Secure Cloud Strategy | The Digital Transformation Agency's (DTA) Secure Cloud Strategy provides guidance for Australian government entities to implement secure cloud computing practices. It emphasises risk management, data sovereignty, security measures, and regulatory compliance. Organisations that use secure cloud services may increase operational efficiency, improve service delivery, and protect | Regulation | Mandatory | Adopting the DTA Secure Cloud Strategy will benefit Prime Health Clinic and Diagnostics by strengthening data security, complying with Australian standards, and increasing operational efficiency. It enables us to rapidly grow services, preserve sensitive patient data, and save infrastructure expenses. This model also promotes innovation, allowing us to swiftly integrate new technologies                                            |

|    |                                                                     |                                                                                                                                                                                                                                                                                                                                                                                                                                                            |                    |           |                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|----|---------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                                                     | sensitive data while remaining agile in digital transformation activities.                                                                                                                                                                                                                                                                                                                                                                                 |                    |           | and improve healthcare services while retaining trust and data sovereignty.                                                                                                                                                                                                                                                                                                                                                                |
| 8  | Health Records and Information Privacy Act 2002 (HRIP Act)          | The <b>HRIP Act</b> is a New South Wales (NSW) law governing the management of health information. It establishes rules for how personal health data should be collected, stored, accessed, and disclosed. The Act provides a framework of 15 Health Privacy Principles (HPPs) that organizations must follow to protect patient confidentiality and privacy.                                                                                              | Regulation         | Mandatory | Compliance with the HRIP Act ensures that PrimeHealth Clinic protects patient health information, maintains trust, and avoids legal penalties. The Act mandates the secure management of sensitive health data to protect individual privacy and prevent unauthorized access or breaches. For clinics, it ensures that patient health records are handled in line with the privacy expectations set by law.                                |
| 9  | COBIT (Control Objectives for Information and Related Technologies) | <b>COBIT</b> is a globally recognized framework for IT governance and management. It provides a comprehensive structure for aligning IT operations with business goals while ensuring compliance with regulatory requirements, risk management, and robust security measures. COBIT covers aspects like information security, risk management, and performance evaluation to help organizations manage their IT and data governance processes effectively. | Framework          | Optional  | Implementing COBIT helps PrimeHealth ensure that its IT infrastructure supports healthcare services efficiently while complying with regulations like the HRIP Act. It promotes better risk management, data security, and governance of health information systems. Although not mandatory, COBIT can significantly improve IT governance, helping the clinic align its technology management with broader business and compliance goals. |
| 10 | Work Health and Safety Act 2011 (WHS Act)                           | A framework to ensure the health and safety of workers and workplaces in Australia, outlining the responsibilities of PCBUs, rights of workers, and incident notification procedures.                                                                                                                                                                                                                                                                      | Legislation        | Mandatory | Compliance with the WHS Act is required by law to protect worker safety, minimize risks, and avoid legal penalties, thus fostering a safe working environment.                                                                                                                                                                                                                                                                             |
| 11 | National Safety and Quality Health Service Standards (NSQHS)        | A set of standards aimed at improving the safety and quality of health services in Australia, focusing on various aspects such as clinical governance, patient safety, and comprehensive care.                                                                                                                                                                                                                                                             | Standards          | Mandatory | Adherence to NSQHS Standards is essential for accreditation and to ensure high-quality patient care, improving safety and satisfaction in healthcare settings.                                                                                                                                                                                                                                                                             |
| 12 | National Health & Medical Research                                  | NHMRC guidelines are to reduce waste, prevent harm, encourage best practice, and promote health.                                                                                                                                                                                                                                                                                                                                                           | Health and Medical | Mandatory | Prime Health is a major actor in the healthcare sector, and to guarantee the best standards of patient care and safety, it                                                                                                                                                                                                                                                                                                                 |

|    |                                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |                         |          |                                                                                                                                                                                                                                                                                                                                                                                    |
|----|------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    | Council (NHMRC) Guidelines               | They are created by panels using a strict evidence-based methodology. Many aspects of clinical practices, ethics, public health, and environmental health are covered by these guidelines.                                                                                                                                                                                                                                                                             | Research Guidelines     |          | must operate by the NHMRC criteria. Maintaining credibility, being certified, and offering healthcare solutions all require all depend on these guidelines                                                                                                                                                                                                                         |
| 13 | Australia's Cyber Security Strategy 2020 | Australia's Cyber Security Strategy 2020 aims to create a more secure online environment for Australians. It involves government investments, industry collaboration, and community education. Key objectives include strengthening cyber defenses, protecting critical infrastructure, and building trust in the digital economy. The strategy outlines measures to enhance cyber capabilities, improve incident response, and raise awareness about online security. | Cybersecurity framework | Optional | Prime Health needs to follow the guidelines specified in the Australia's Cyber Security Strategy 2020 as it can benefit Prime Health clinics by protecting patient data, preventing disruptions to critical services, and maintaining public trust. This strategy helps clinics comply with regulations, reduce financial losses, and improve their overall cybersecurity posture. |

|    |                  |                                                                                                                                                                                                                                                                                                             |           |           |                                                                                                                                                                                                                                                                                                                                                                |
|----|------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 14 | Privacy Act 1988 | Australian Law that governs the handling of personal information by Australia Government agencies with annual sales above \$3 million. Among with the standards for gathering, use, storage, and disclosing personal data are the Australian Privacy Principles (APPs)                                      | Framework | Mandatory | To preserve patient data and maintain privacy, Prime Health must comply with the Privacy Act 1988 and the Apps. It is important to comply with these principles to maintaining trust, protecting personal data, and following the legal requirements                                                                                                           |
| 15 | ISO/IEC 27001    | ISO/IEC 27001 is an international standard that provides a framework for establishing, implementing, maintaining, and continuously improving an Information Security Management System (ISMS). It is designed to protect sensitive information by applying risk management processes and security controls. | Standard  | Mandatory | ISO/IEC 27001 is mandatory for PrimeHealth to achieve certification which will help the organization to demonstrate its commitment to information security. It is required for regulatory reasons or client contracts, particularly in industries that handle sensitive data, such as healthcare and finance.                                                  |
| 16 | ISO/IEC 27002    | ISO/IEC 27002 draws codes of practices and provides guidelines on how an organization can begin, build, apply, measure, and improve its information security management. It serves as a guide when choosing security controls inside the ISMS, which is elucidated by the ISO/IEC 27001.                    | Standard  | Mandatory | ISO/IEC 27002 is a requirement for PrimeHealth to implement and verify that an organization has implemented the best information security. By following this standard, it is possible to improve the overall performance of ISMS and guarantee optimal levels of security.                                                                                     |
| 17 | ISO 27005        | This standard encompasses various elements, such as outlining the process scope, valuing assets, evaluating their impact, offering examples of common threats, vulnerabilities, and methods to assess vulnerabilities, along with approaches for assessing information security risks.                      | Standard  | Mandatory | ISO 27005 is essential for PrimeHealth as it provides a structured approach to managing information security risks, ensuring the protection of sensitive health data and compliance with regulatory requirements. This standard supports PrimeHealth's commitment to safeguarding patient information and maintaining trust through proactive risk management. |

|    |                         |                                                                                                                           |          |          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|----|-------------------------|---------------------------------------------------------------------------------------------------------------------------|----------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 18 | ISO/IEC 15189<br>(2023) | ISO15189 is an international standard that specifies the requirements for quality and competence in medical laboratories. | Standard | Optional | Not mandatory.<br>However, it is strongly suggested that any company that wants to provide pathology laboratory services should be ISO15189 accredited, as benefits such as Australia's Medicare might be difficult to obtain without accreditation. It is also strongly recommended, as this accreditation ensures the quality and reliability of services, which would be points that partner (such as hospitals, clinics, etc. without their own pathology department) and customers would look for. |
|----|-------------------------|---------------------------------------------------------------------------------------------------------------------------|----------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|